

Checkov Security Report - TrueTally

Checkov Security Scan Report - TrueTally Terraform

Error Detectado 1: CKV2_AWS_46

Política: Ensure AWS CloudFront Distribution with S3 have Origin Access set to enabled

Severidad: MEDIUM

Descripción: Cuando CloudFront está conectado a un origen S3, debe usarse Origin Access Identity (OAI) para evitar que el bucket sea accesible públicamente. Sin OAI, cualquier usuario puede acceder directamente al bucket S3 si las políticas lo permiten.

Antes (Código con fallo)

```
resource "aws_cloudfront_distribution" "frontend" {
  origin {
    domain_name = aws_s3_bucket.frontend.bucket_regional_domain_name
    origin_id   = "s3-origin"
    # FALTA s3_origin_config con OAI
  }
}
```

Solución

Se agregaron recursos en terraform/modules/frontend/main.tf: -
aws_cloudfront_origin_access_identity - aws_s3_bucket_policy con acceso restringido al OAI - s3_origin_config en CloudFront con el OAI

Resultado Checkov: PASSED

Error Detectado 2: CKV2_AWS_30

Política: Ensure Postgres RDS has Query Logging enabled

Severidad: MEDIUM

Antes (Código con fallo)

```
resource "aws_db_instance" "main" {
  # ... sin enabled_cloudwatch_logs_exports ...
}
```

Solución

En terraform/modules/database/main.tf:

```
resource "aws_db_instance" "main" {
  enabled_cloudwatch_logs_exports = ["postgresql", "upgrade"]
}
```

Resultado Checkov: PASSED

Integración CI/CD

Checkov se integró en `.github/workflows/terraform.yml` como job security:

```
jobs:
  security:
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@v4
      - uses: bridgecrewio/checkov-action@master
        with:
          directory: terraform
          soft_fail: false
          skip_check: CKV2_AWS_62
```

Checks skippeados: CKV2_AWS_62 (event notifications no aplican a bucket frontend estático)